

Documentación Técnica Profesional

Políticas Corporativas en FortiGate Firewall

WAF - APP - DNS - DHCP

Estudiante	Michael Robles
Matrícula	2025-0845
Repositorio	https://github.com/iClexi/Fortigate-Corporate-Policies
Video	https://youtu.be/9Mjof5YxtKg?si=TpSuH9TQf1OwJGXo
Plataforma	FortiGate VM64-KVM en GNS3
Fecha	Julio 2026

Índice

1. Topología y alcance
2. Direccionamiento, rutas e interfaces
3. DHCP y resolución DNS
4. Políticas de firewall y segmentación
5. Bloqueo web, DNS y aplicaciones
6. Detección y bloqueo de escáneres
7. Validación de acceso web permitido
8. Web Application Firewall
9. Conclusión

1. Resumen ejecutivo

Este documento describe y valida la implementación de políticas corporativas en un FortiGate Firewall dentro de GNS3. La práctica integra segmentación de redes, salida a Internet con NAT, DHCP para usuarios, políticas de control entre usuarios y servidores, filtrado web, control de aplicaciones, bloqueo por DNS, detección de escáneres de red y protección del servidor web mediante Web Application Firewall.

La documentación se organiza por temas técnicos y no por el orden en que fueron enviadas las capturas. Cada evidencia se explica según lo que aparece en pantalla para que el lector entienda qué componente se valida y por qué es importante dentro del laboratorio.

2. Datos técnicos del laboratorio

Red de usuarios	10.8.45.0/25
Gateway usuarios	10.8.45.1 en LAN_USUARIOS port2
Rango DHCP usuarios	10.8.45.20 - 10.8.45.120
Red de servidores	10.8.45.128/28
Gateway servidores	10.8.45.129 en LAN_SERVIDORES port3
Servidor web	10.8.45.130
WAN FortiGate	192.168.42.103/24, gateway 192.168.42.1

3. Topología y alcance

La topología define la separación de zonas. El FortiGate funciona como punto de control entre Internet, usuarios y servidores. Esta separación permite aplicar reglas diferentes por interfaz y validar el comportamiento de cada política.

Topología del laboratorio

La topología presenta al FortiGate como dispositivo central entre Internet, la LAN de usuarios y la LAN de servidores. A la izquierda está el switch de usuarios con la estación Secretaria. A la derecha está el switch de servidores con el Web Server. También se muestra el nombre Michael Robles, la matrícula 20250845 y el alcance general de la práctica: WAF, APP, DNS y DHCP.

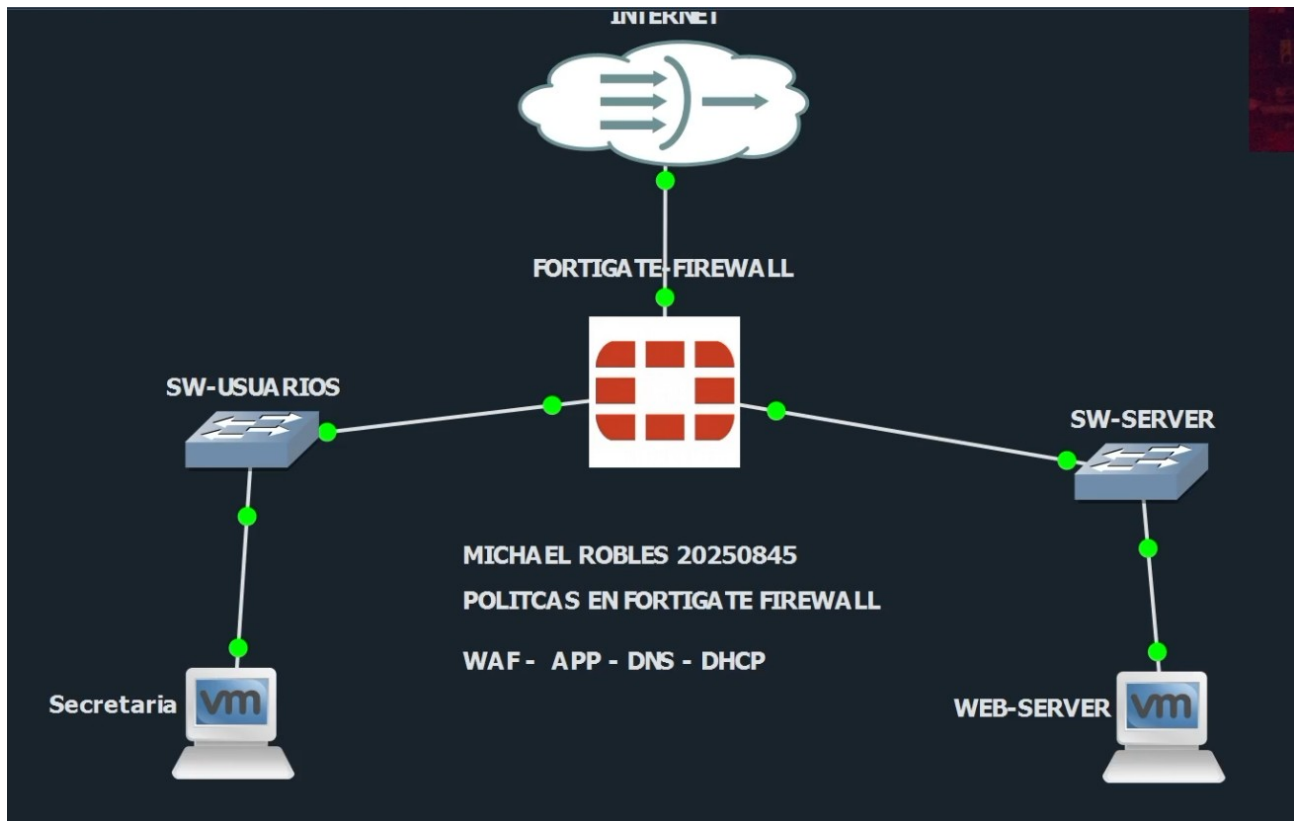


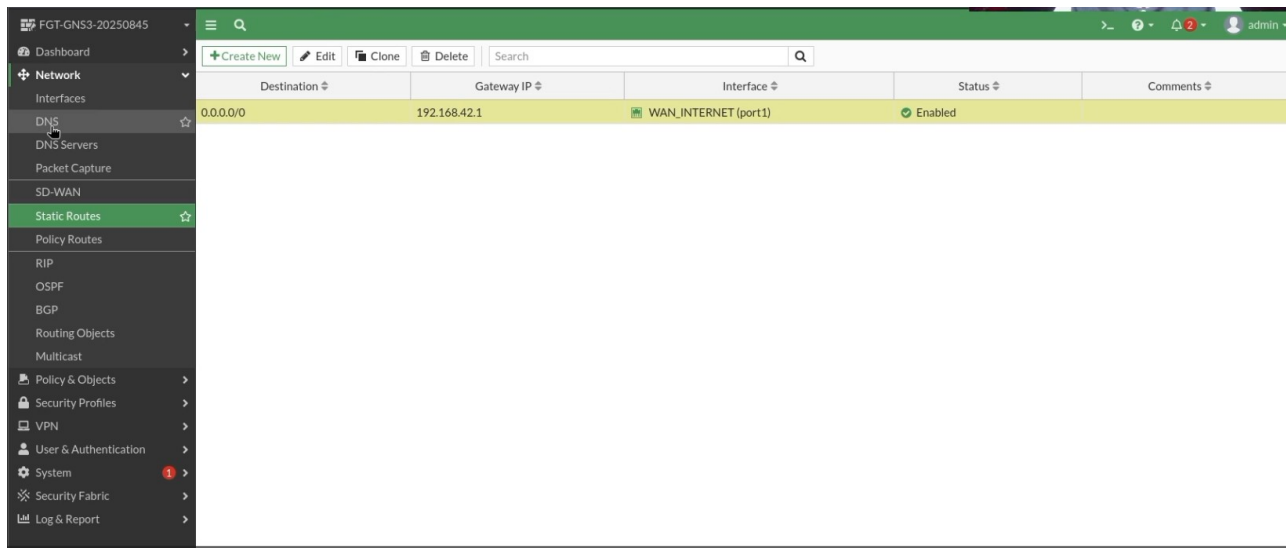
Figura 1. Topología del laboratorio.

4. Direccionamiento, rutas e interfaces

El direccionamiento se configuró por interfaces físicas. La interfaz WAN permite la salida hacia Internet, port2 representa la LAN de usuarios y port3 representa la LAN de servidores. La ruta estática por defecto envía el tráfico externo hacia el gateway de la red NAT.

Ruta estática por defecto

La ruta por defecto 0.0.0.0/0 apunta al gateway 192.168.42.1 mediante la interfaz WAN_INTERNET port1. Esta ruta permite que el FortiGate envíe hacia Internet todo tráfico cuyo destino no pertenezca a una red local conocida.

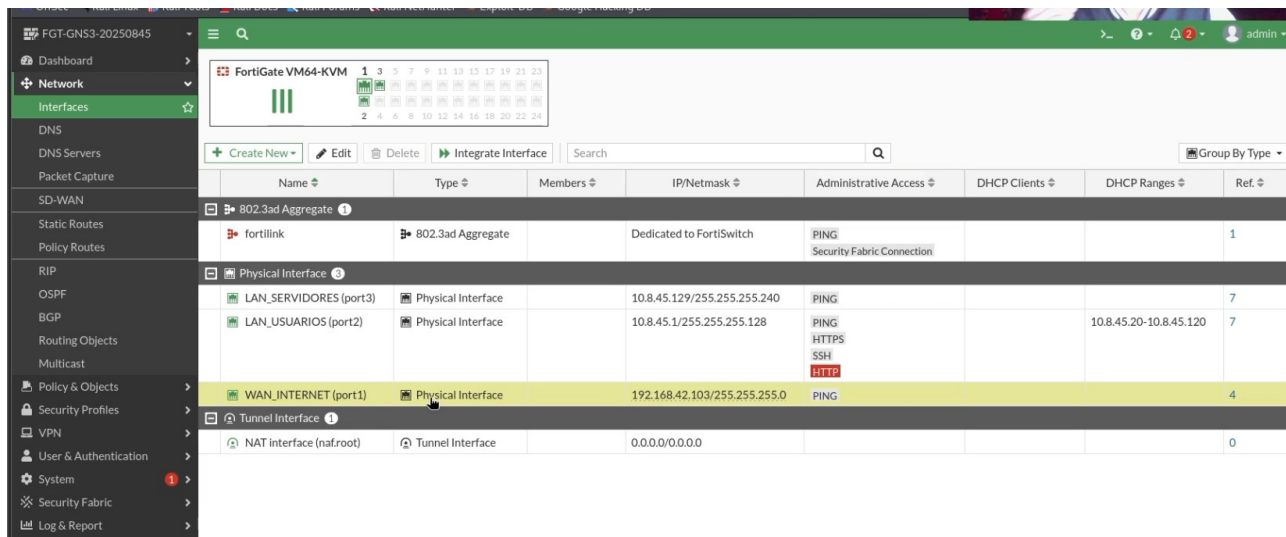


Destination	Gateway IP	Interface	Status	Comments
0.0.0.0/0	192.168.42.1	WAN_INTERNET (port1)	Enabled	

Figura 2. Ruta estática por defecto.

Resumen de interfaces del FortiGate

El panel de interfaces muestra las tres zonas del laboratorio: WAN_INTERNET en port1 con IP 192.168.42.103/24, LAN_USUARIOS en port2 con IP 10.8.45.1/25 y LAN_SERVIDORES en port3 con IP 10.8.45.129/28. También se observa el rango DHCP para usuarios de 10.8.45.20 a 10.8.45.120.



Name	Type	Members	IP/Netmask	Administrative Access	DHCP Clients	DHCP Ranges	Ref.
802.3ad Aggregate							
fortilink	802.3ad Aggregate		Dedicated to FortiSwitch	PING Security Fabric Connection			1
Physical Interface							
LAN_SERVIDORES (port3)	Physical Interface		10.8.45.129/255.255.240	PING			7
LAN_USUARIOS (port2)	Physical Interface		10.8.45.1/255.255.128	PING HTTPS SSH HTTP		10.8.45.20-10.8.45.120	7
WAN_INTERNET (port1)	Physical Interface		192.168.42.103/255.255.0	PING			4
Tunnel Interface							
NAT interface (natroot)	Tunnel Interface		0.0.0.0/0.0.0.0				0

Figura 3. Resumen de interfaces del FortiGate.

Configuración de port2 como LAN de usuarios

La interfaz LAN_USUARIOS port2 está configurada manualmente con 10.8.45.1/25. Esta dirección funciona como puerta de enlace de la red de usuarios 10.8.45.0/25. En el acceso administrativo se ven habilitados HTTPS, HTTP, SSH y PING para administración y pruebas internas del laboratorio.

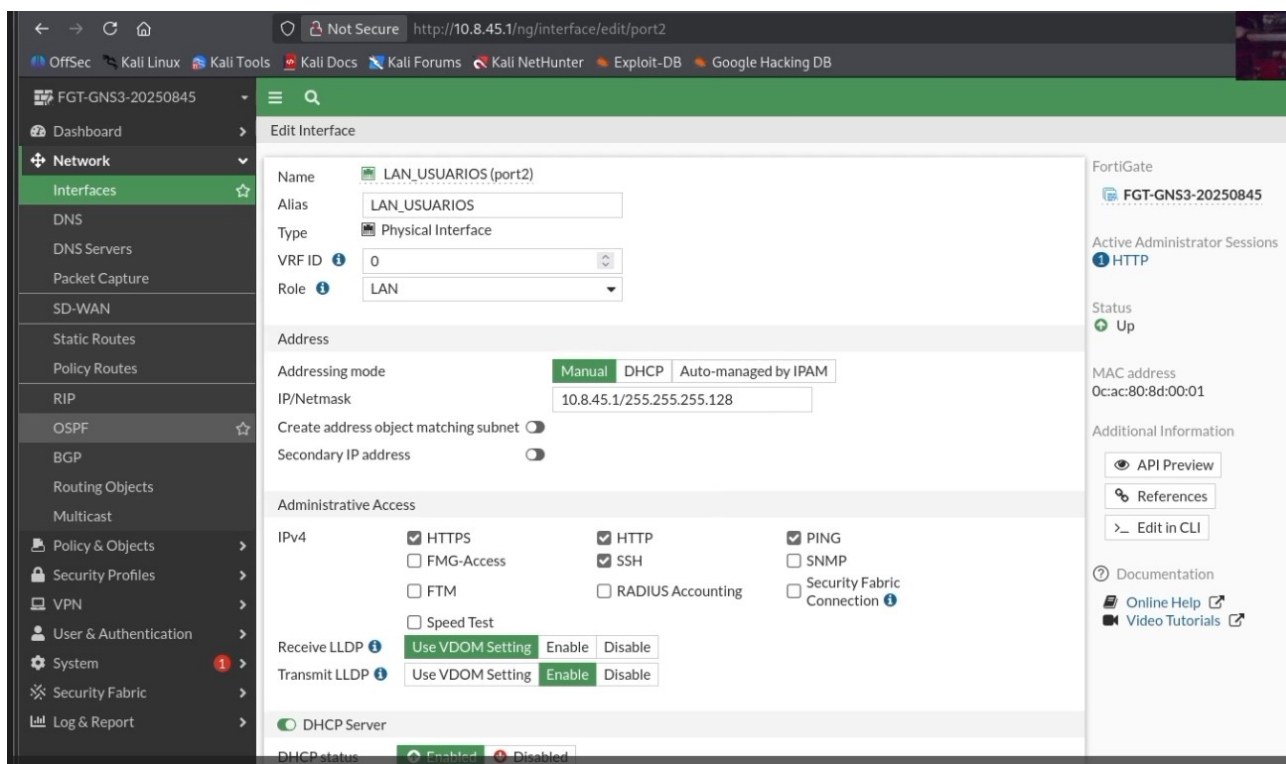


Figura 4. Configuración de port2 como LAN de usuarios.

5. DHCP y resolución DNS

El servicio DHCP se limitó a la LAN de usuarios. Los clientes reciben gateway y DNS del FortiGate, lo que permite aplicar resolución interna y redirección de dominios bloqueados sin depender de DNS externos en la estación de trabajo.

DHCP en la LAN de usuarios

El servidor DHCP de port2 está habilitado con rango 10.8.45.20-10.8.45.120, máscara 255.255.255.128, puerta de enlace igual a la IP de la interfaz y DNS 10.8.45.1. Esto hace que los equipos de la LAN de usuarios reciban parámetros de red directamente desde el FortiGate.

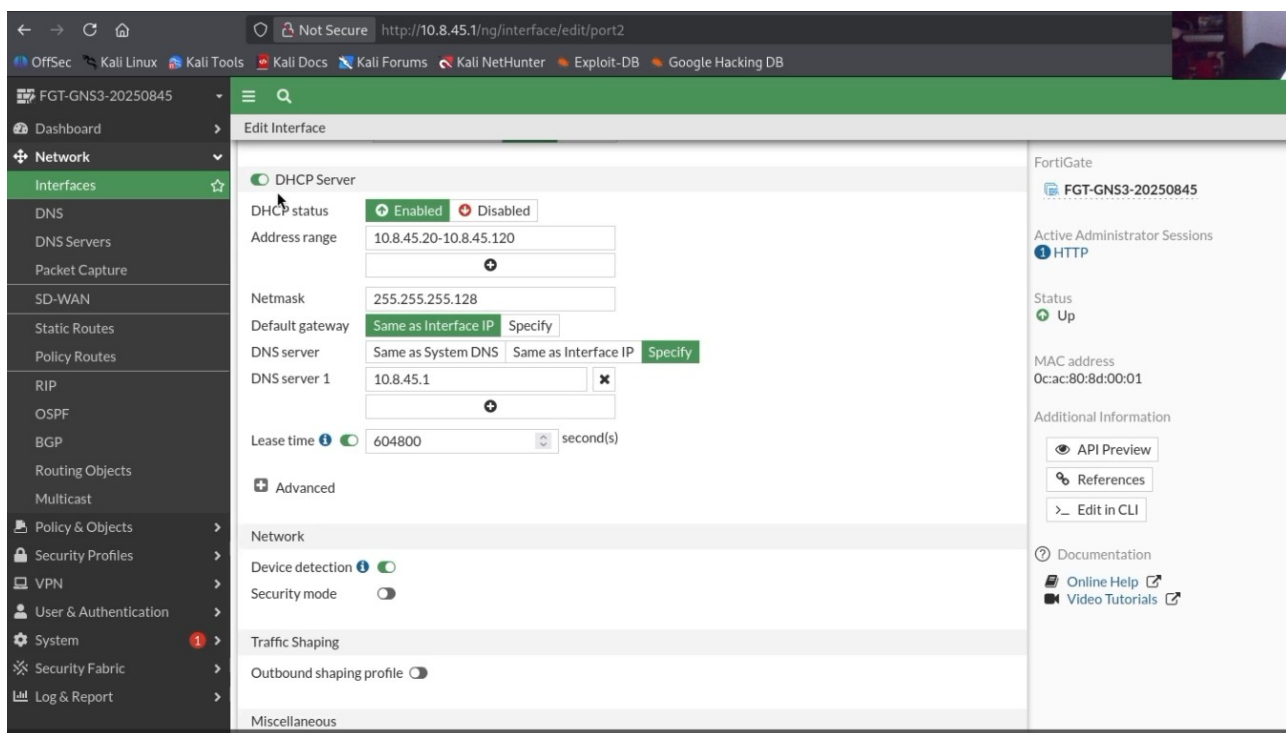


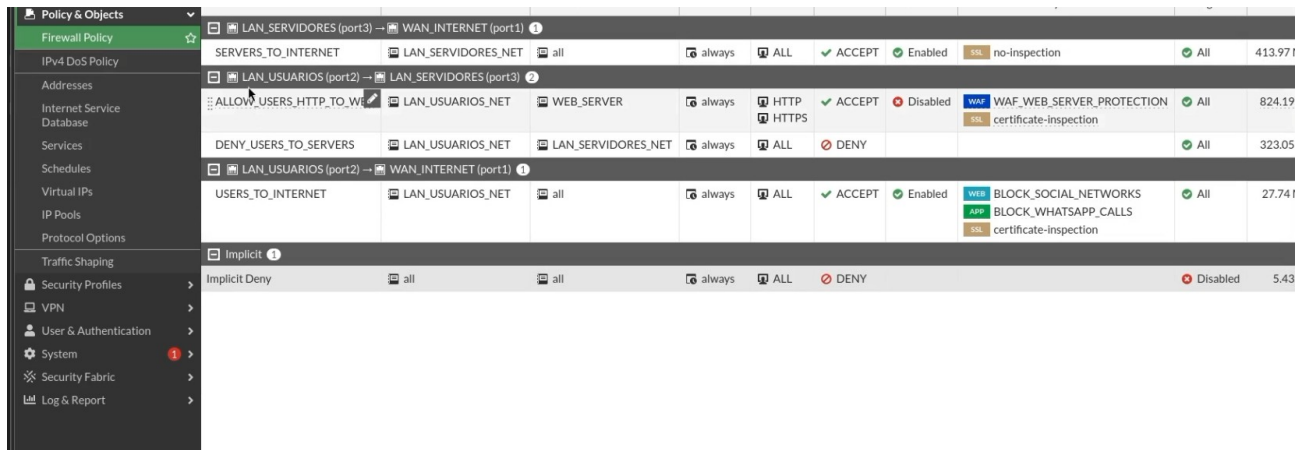
Figura 5. DHCP en la LAN de usuarios.

6. Políticas de firewall y segmentación

Las políticas de firewall definen qué flujo está permitido y cuál queda bloqueado. La salida a Internet usa NAT. El acceso hacia servidores queda controlado por una regla específica de tráfico web y una regla de denegación para todo lo demás.

Resumen de políticas de firewall

La vista general de políticas agrupa los flujos principales: servidores hacia Internet, usuarios hacia servidores y usuarios hacia Internet. Se observan las reglas de salida, la regla que permite tráfico web hacia el servidor y la regla que deniega el resto del tráfico desde usuarios hacia la red de servidores.

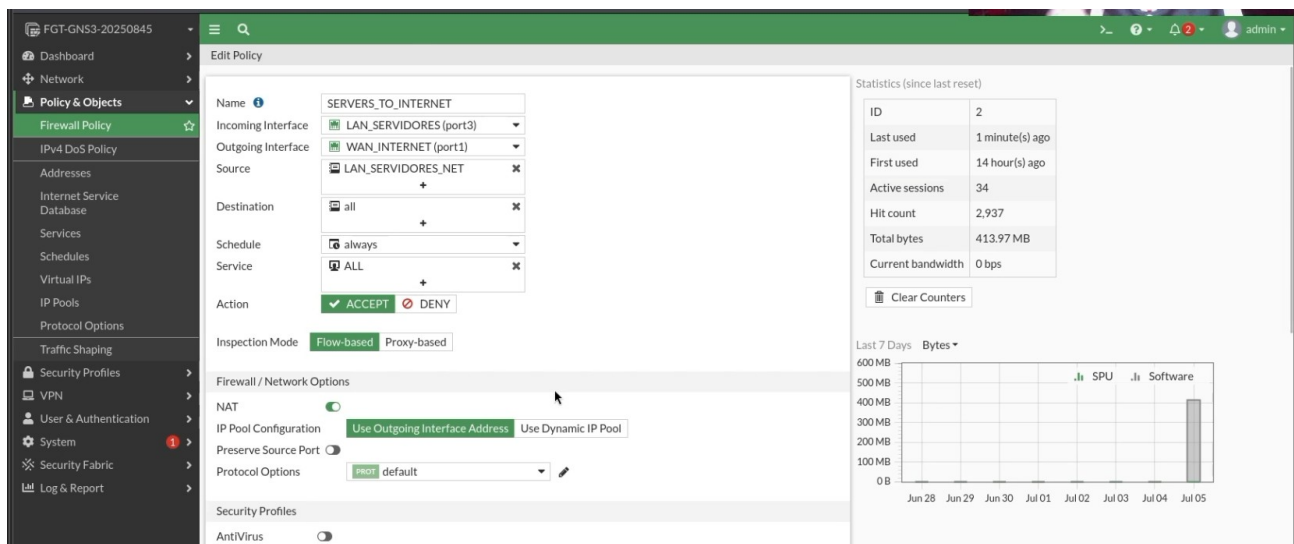


Policy Name	Source	Destination	Service	Action	Status	Inspection	Hit Count
SERVERS_TO_INTERNET	LAN_SERVIDORES (port3)	WAN_INTERNET (port1)	all	ACCEPT	Enabled	no-inspection	413.97 MB
ALLOW_USERS_HTTP_TO_WEB	LAN_USUARIOS (port2)	LAN_SERVIDORES (port3)	HTTP, HTTPS	ACCEPT	Disabled	WAF, WAF_WEB_SERVER_PROTECTION, certificate-inspection	824.19 MB
DENY_USERS_TO_SERVERS	LAN_USUARIOS (port2)	LAN_SERVIDORES (port3)	all	DENY	Enabled		323.05 MB
LAN_USUARIOS (port2) to WAN_INTERNET (port1)	LAN_USUARIOS (port2)	WAN_INTERNET (port1)	all	ACCEPT	Enabled	BLOCK_SOCIAL_NETWORKS, BLOCK_WHATSAPP_CALLS, certificate-inspection	27.74 MB
USERS_TO_INTERNET	LAN_USUARIOS (port2)	WAN_INTERNET (port1)	all	ACCEPT	Enabled		27.74 MB
Implicit Deny	all	all	all	DENY	Disabled		5.43 MB

Figura 6. Resumen de políticas de firewall.

Política de servidores hacia Internet

La política SERVERS_TO_INTERNET permite que LAN_SERVIDORES_NET salga hacia WAN_INTERNET. Usa destino all, servicio ALL y acción ACCEPT. También se observa NAT habilitado, usando la dirección de salida de la interfaz.



Edit Policy: SERVERS_TO_INTERNET

Configuration:

- Name: SERVERS_TO_INTERNET
- Incoming Interface: LAN_SERVIDORES (port3)
- Outgoing Interface: WAN_INTERNET (port1)
- Source: LAN_SERVIDORES_NET
- Destination: all
- Schedule: always
- Service: ALL
- Action: ACCEPT
- Inspection Mode: Flow-based
- NAT: Enabled
- IP Pool Configuration: Use Outgoing Interface Address
- Protocol Options: default

Statistics (since last reset):

ID	2
Last used	1 minute(s) ago
First used	14 hour(s) ago
Active sessions	34
Hit count	2,937
Total bytes	413.97 MB
Current bandwidth	0 bps

Last 7 Days Bytes:

Bar chart showing traffic volume in bytes from Jun 28 to Jul 05. The chart shows a significant spike in traffic on Jul 05, reaching approximately 500 MB.

Figura 7. Política de servidores hacia Internet.

Opciones de seguridad en la salida de servidores

La segunda parte de SERVERS_TO_INTERNET muestra el modo flow-based, NAT activo y los perfiles de seguridad apagados. Esta regla se usa solo para salida básica de la red de servidores, separada de los controles aplicados a usuarios.

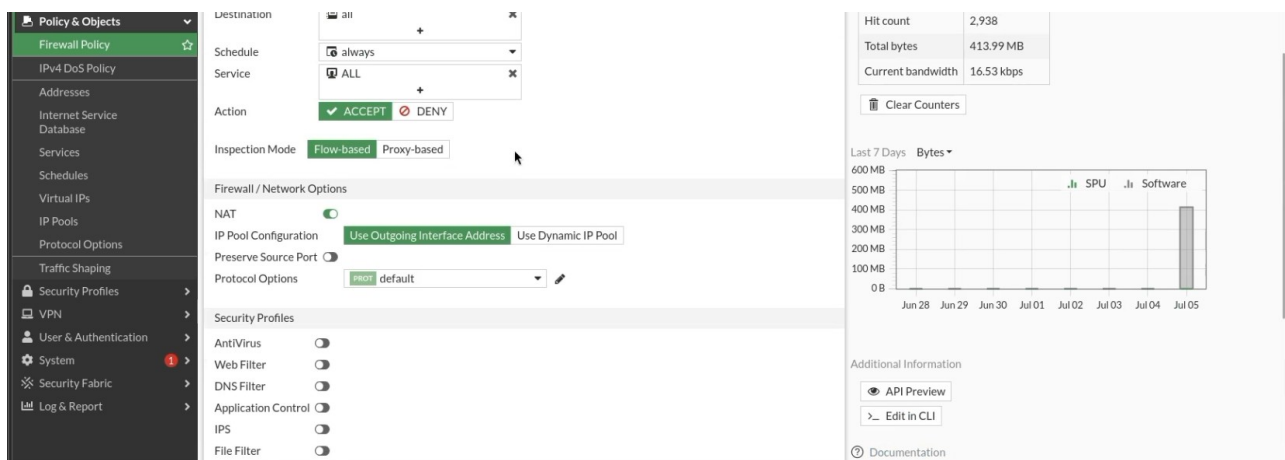


Figura 8. Opciones de seguridad en la salida de servidores.

Política que permite acceso web al servidor

La política ALLOW_USERS_HTTP_TO_WEB permite tráfico desde LAN_USUARIOS_NET hacia el objeto WEB_SERVER por port3. En la captura se ven los servicios HTTP y HTTPS, acción ACCEPT, NAT deshabilitado y modo proxy-based. La regla limita el destino al servidor web y tiene aplicado el perfil WAF_WEB_SERVER_PROTECTION.

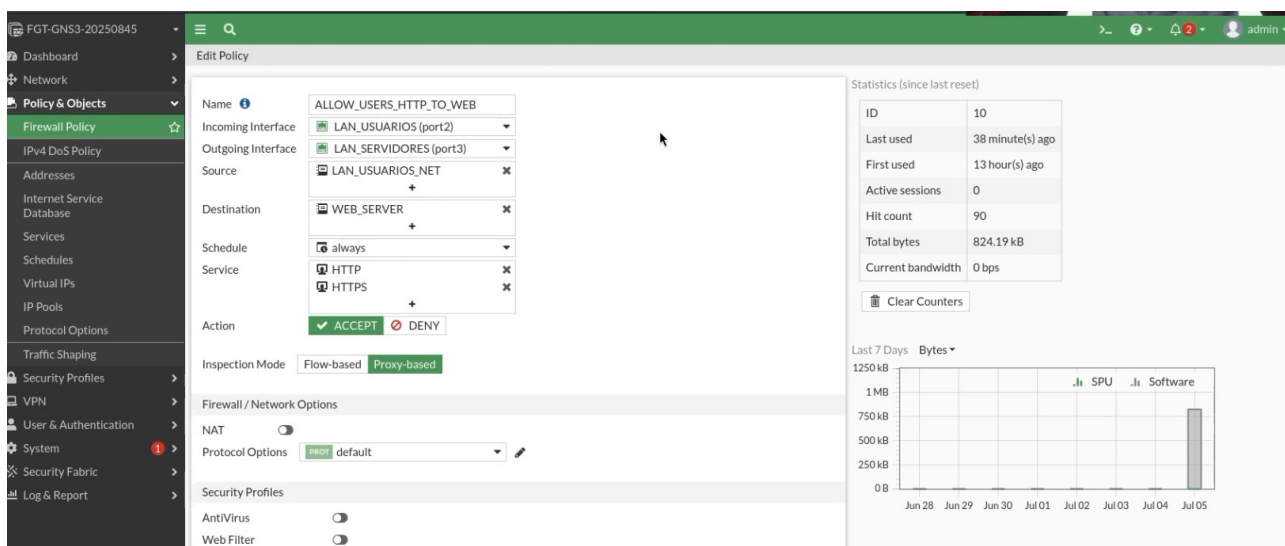


Figura 9. Política que permite acceso web al servidor.

Denegación del resto del tráfico hacia servidores

La política DENY_USERS_TO_SERVERS bloquea todo tráfico de LAN_USUARIOS_NET hacia LAN_SERVIDORES_NET que no sea permitido por una regla superior. La acción es DENY, el servicio es ALL y está habilitado el registro de tráfico de violación.

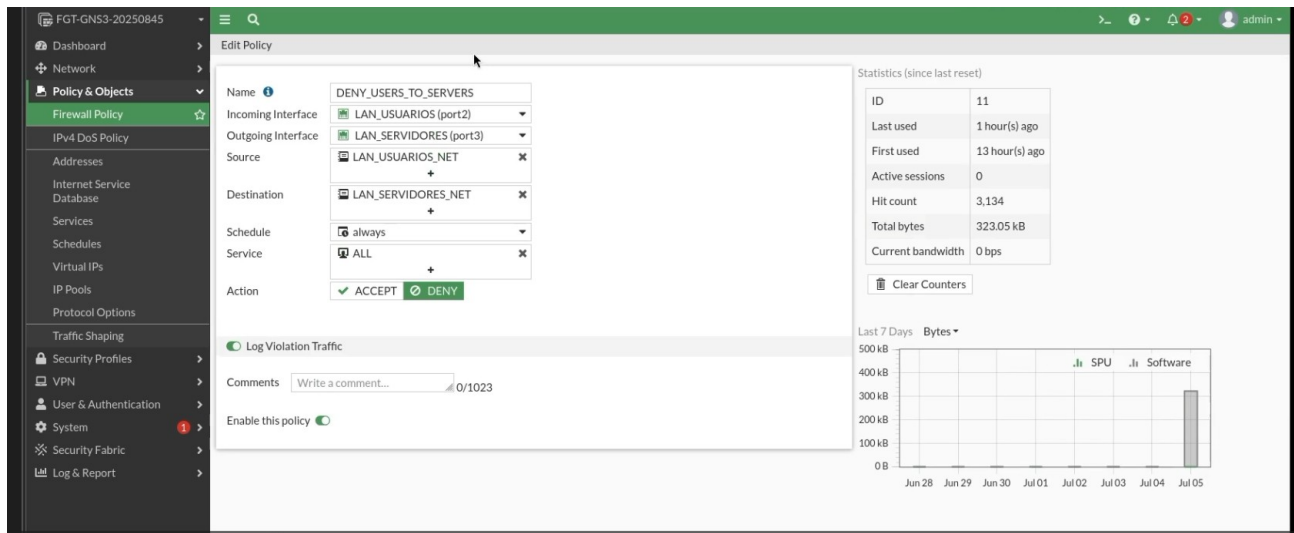


Figura 10. Denegación del resto del tráfico hacia servidores.

Política de usuarios hacia Internet

La política USERS_TO_INTERNET permite que LAN_USUARIOS_NET salga hacia WAN_INTERNET con servicio ALL y NAT habilitado. Esta regla es la base del acceso a Internet de usuarios y es donde se aplican los perfiles de Web Filter y Application Control.

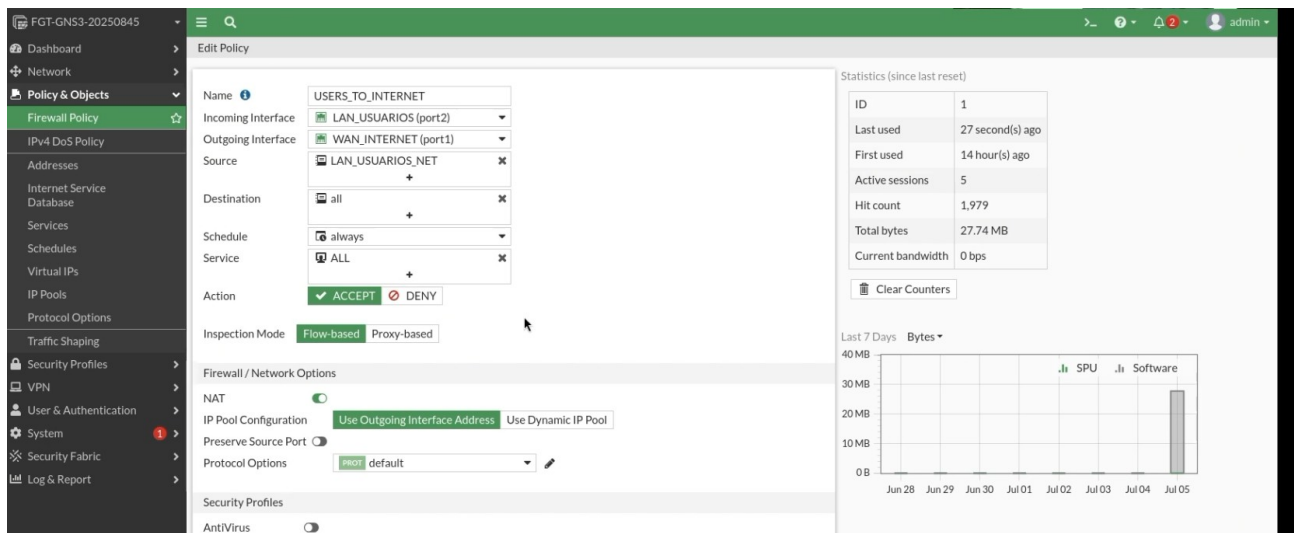


Figura 11. Política de usuarios hacia Internet.

7. Bloqueo web, DNS y aplicaciones

El control de navegación se implementó con varios mecanismos: Web Filter para redes sociales, URL estáticas, DNS Filter para itla.edu.do y Application Control para llamadas de WhatsApp. La combinación permite demostrar bloqueo por dominio, categoría y aplicación.

Perfil Web Filter para redes sociales

El perfil BLOCK_SOCIAL_NETWORKS aparece dentro de Security Profiles > Web Filter. La pantalla muestra la advertencia de licencia de FortiGuard, por lo que además del filtro por categoría se apoya el bloqueo con URL estáticas y DNS local.

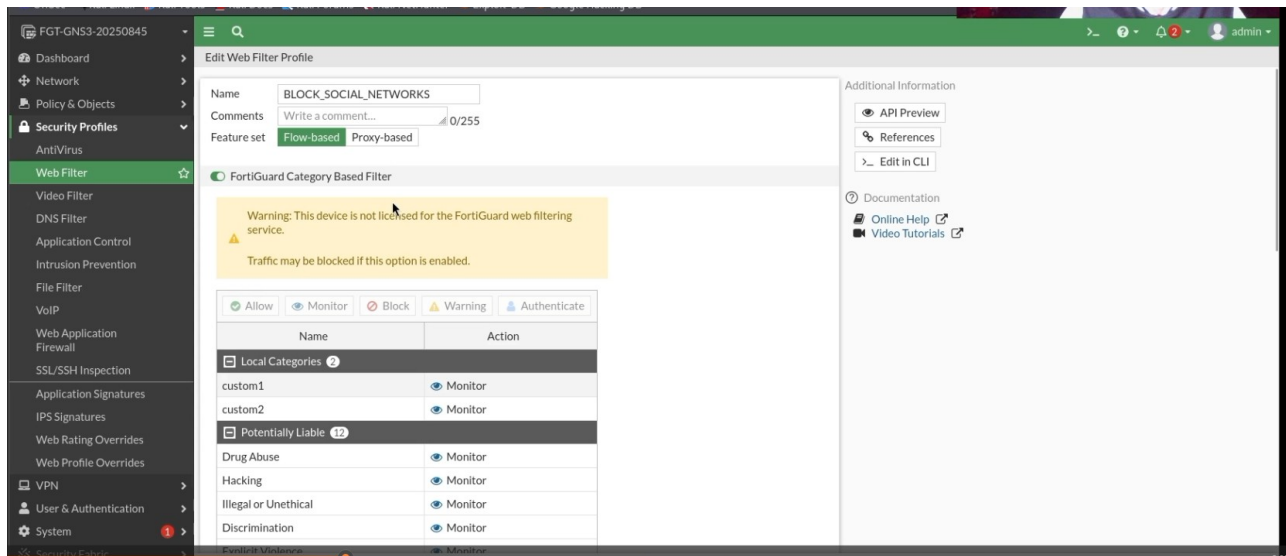


Figura 12. Perfil Web Filter para redes sociales.

Categoría Social Networking bloqueada

Dentro del perfil Web Filter se observa la categoría Social Networking con acción Block. Esta configuración representa el control por categoría para impedir el uso de redes sociales desde la LAN de usuarios.

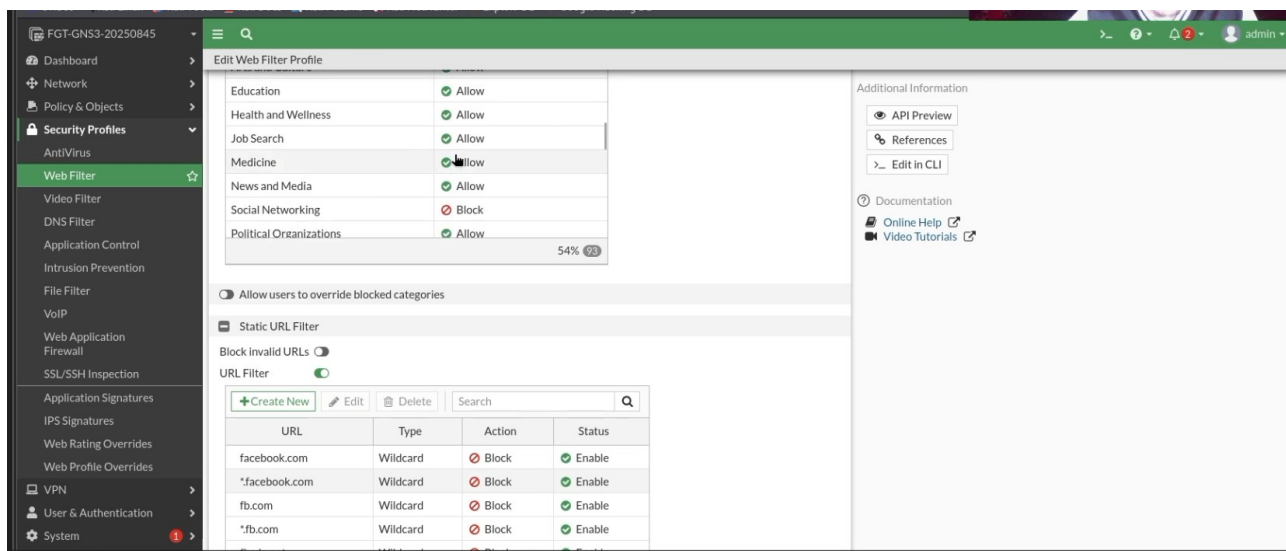


Figura 13. Categoría Social Networking bloqueada.

Filtro estático de URL para redes sociales

El Static URL Filter está habilitado y contiene dominios como facebook.com, *.facebook.com, fb.com, *.fb.com, fbcdn.net, *.fbcdn.net, fbsbx.com y messenger.com. Las entradas se muestran como wildcard, con acción Block y estado Enable.

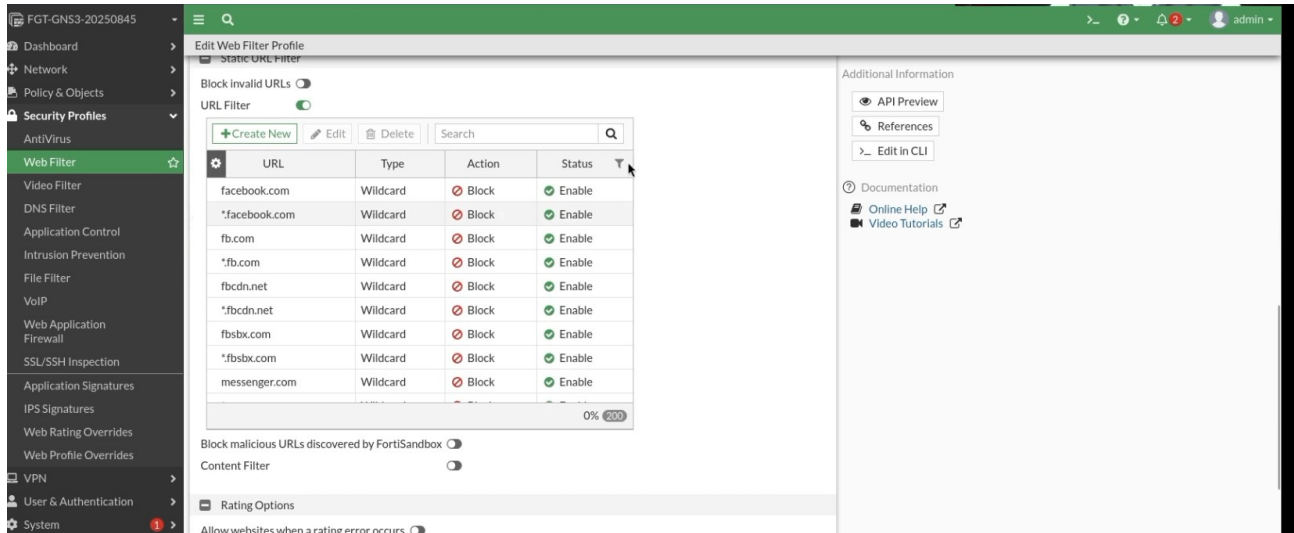


Figura 14. Filtro estático de URL para redes sociales.

Perfil de Application Control para WhatsApp

La lista de Application Control muestra el perfil BLOCK_WHATSAPP_CALLS con referencia activa. Este perfil centraliza el control de aplicaciones relacionado con WhatsApp, principalmente para bloquear llamadas VoIP.

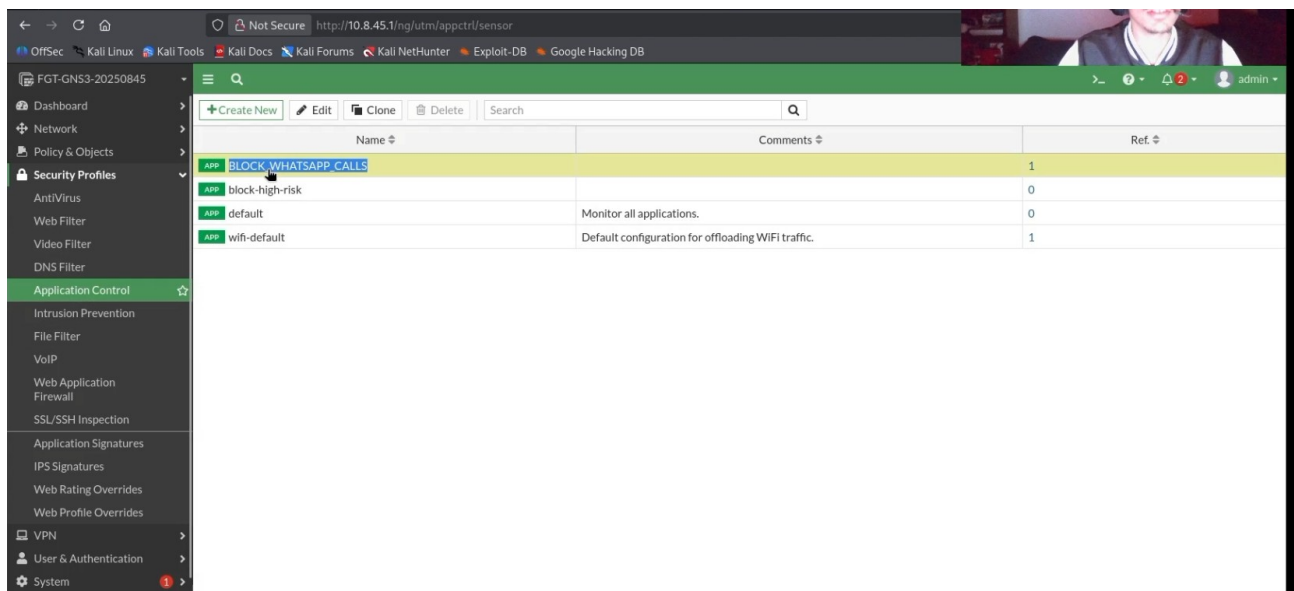


Figura 15. Perfil de Application Control para WhatsApp.

Firma WhatsApp VoIP bloqueada

Dentro del sensor BLOCK_WHATSAPP_CALLS se observa una regla con la firma WhatsApp_VoIP.Call, tipo Application y acción Block. También se ve QUIC en Block, lo que ayuda a evitar que ciertas aplicaciones usen QUIC para evadir controles tradicionales.

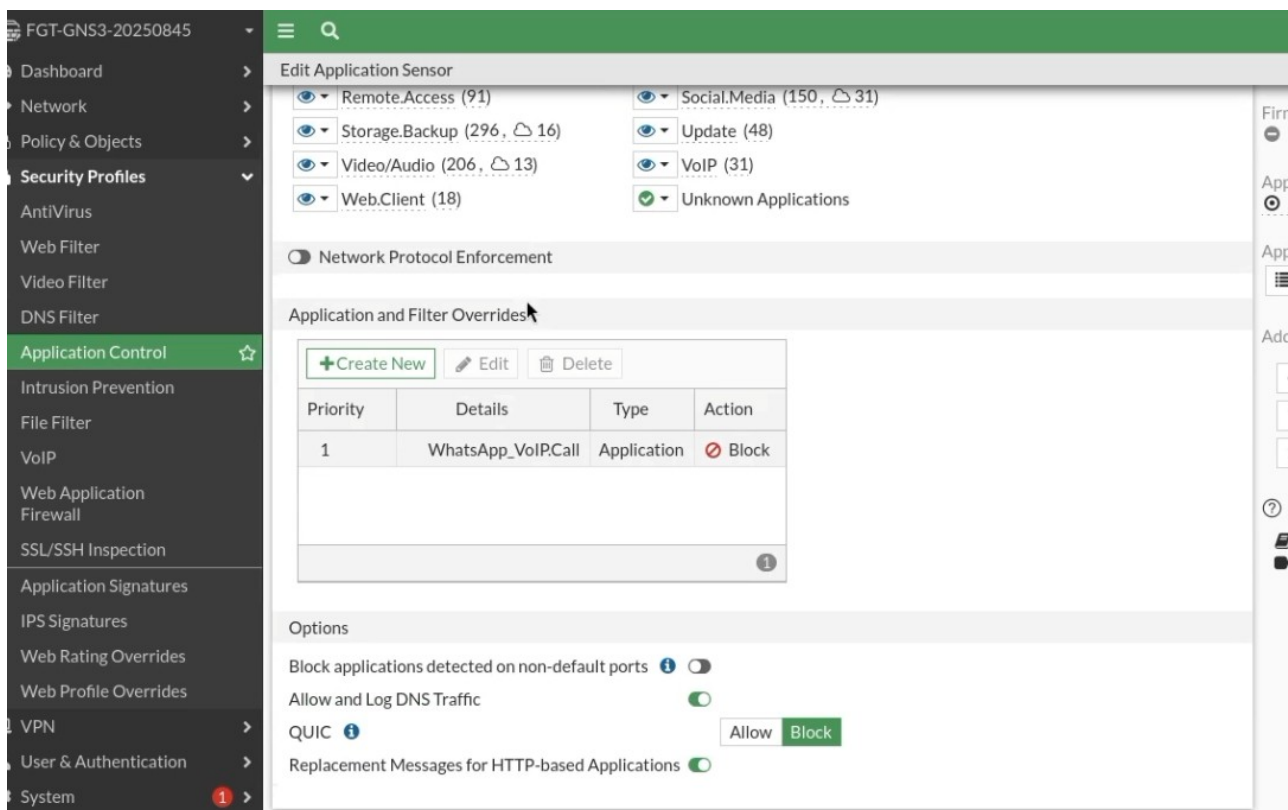


Figura 16. Firma WhatsApp VoIP bloqueada.

DNS Filter para itla.edu.do y subdominios

El perfil BLOCK_ITLA_DNS contiene un Static Domain Filter con itla.edu.do tipo simple y *.itla.edu.do tipo wildcard. Ambas entradas están configuradas como Redirect to Block Portal y están habilitadas.

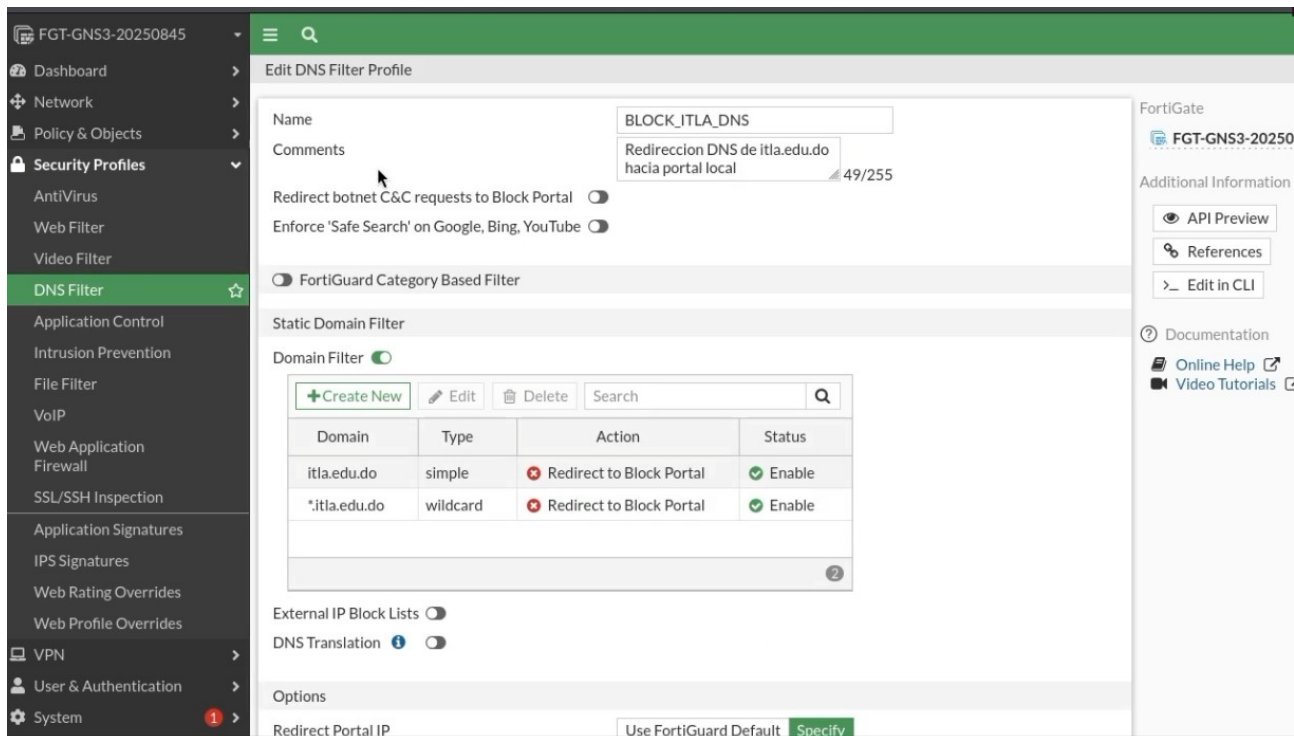


Figura 17. DNS Filter para itla.edu.do y subdominios.

Portal de bloqueo al acceder a itla.edu.do

La navegación hacia itla.edu.do muestra el portal interno con el mensaje Acceso bloqueado. La página indica que el dominio o dirección solicitada viola las políticas de la empresa, validando la redirección del dominio bloqueado.

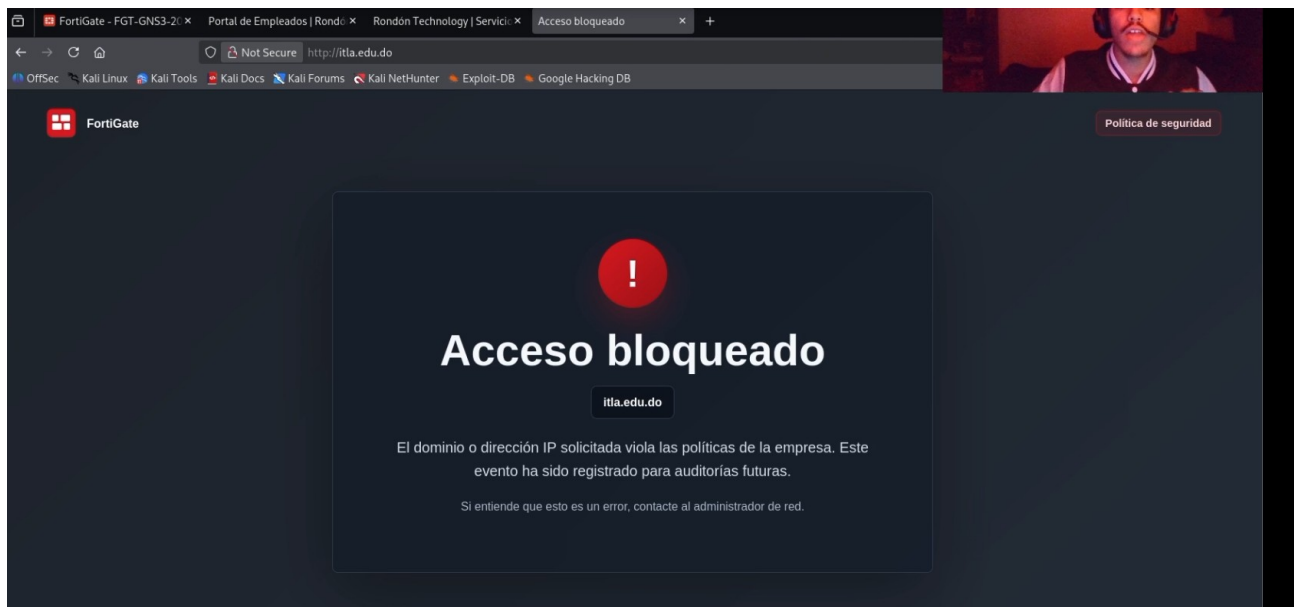


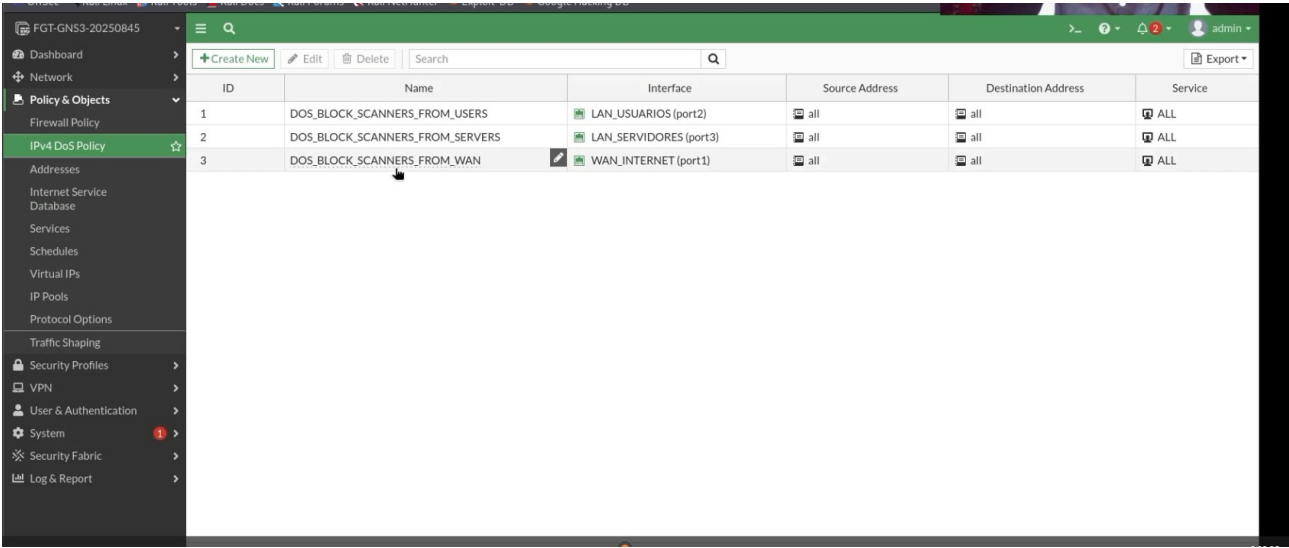
Figura 18. Portal de bloqueo al acceder a itla.edu.do.

8. Detección y bloqueo de escáneres

Las políticas DoS detectan patrones anómalos como escaneo TCP, escaneo UDP, barridos ICMP y floods. Las pruebas con Nmap generan eventos visibles en Forward Traffic y Anomaly, mostrando tanto el bloqueo por política como el cierre de sesiones anómalas.

Resumen de políticas IPv4 DoS

La sección IPv4 DoS Policy muestra tres políticas: DOS_BLOCK_SCANNERS_FROM_USERS en port2, DOS_BLOCK_SCANNERS_FROM_SERVERS en port3 y DOS_BLOCK_SCANNERS_FROM_WAN en port1. Esto evidencia protección para usuarios, servidores y zona WAN.



ID	Name	Interface	Source Address	Destination Address	Service
1	DOS_BLOCK_SCANNERS_FROM_USERS	LAN_USUARIOS (port2)	all	all	ALL
2	DOS_BLOCK_SCANNERS_FROM_SERVERS	LAN_SERVIDORES (port3)	all	all	ALL
3	DOS_BLOCK_SCANNERS_FROM_WAN	WAN_INTERNET (port1)	all	all	ALL

Figura 19. Resumen de políticas IPv4 DoS.

DoS Policy para usuarios - inicio de anomalías

La política DOS_BLOCK_SCANNERS_FROM_USERS aplica sobre LAN_USUARIOS port2, con origen all, destino all y servicio ALL. En L3 se monitorean ip_src_session e ip_dst_session con umbral 200. En L4 se observan tcp_syn_flood y tcp_port_scan en Block.

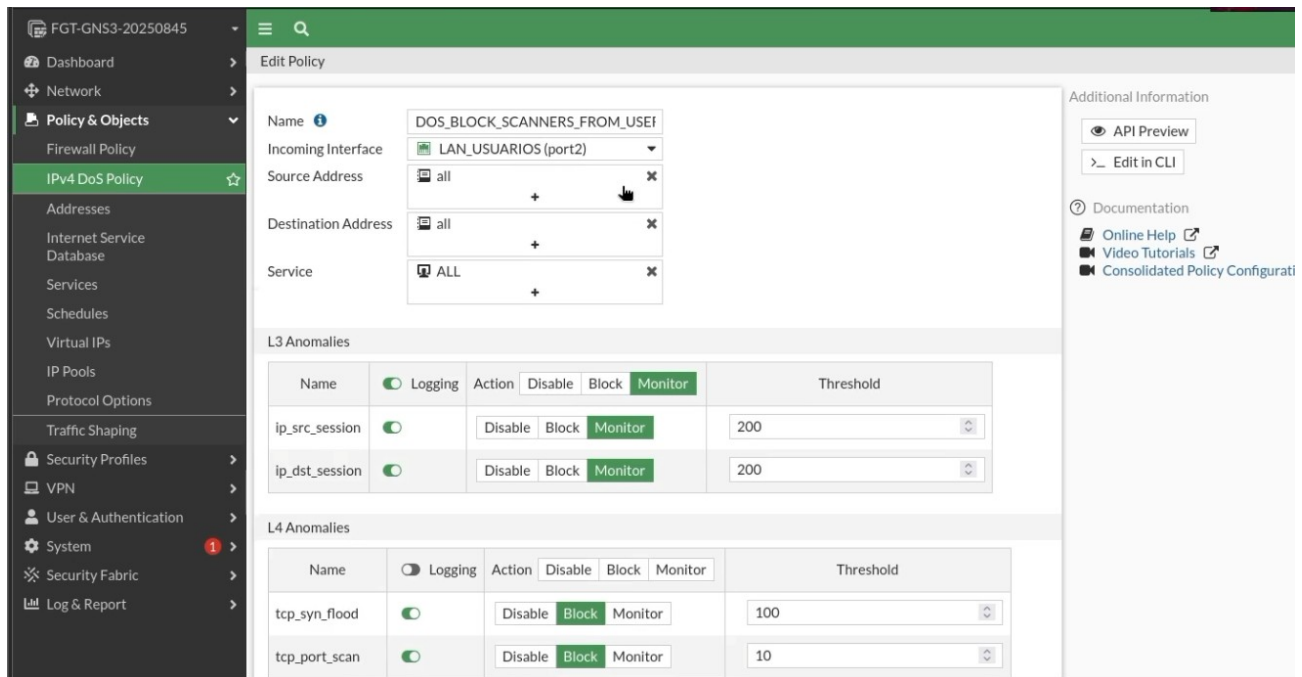


Figura 20. DoS Policy para usuarios - inicio de anomalías.

DoS Policy para usuarios - anomalías TCP, UDP e ICMP

La segunda vista muestra tcp_syn_flood, tcp_port_scan, udp_flood, udp_scan, icmp_flood e icmp_sweep con acción Block y umbrales definidos. Las sesiones por origen y destino quedan en Monitor para observar volumen anormal sin bloquear todo el tráfico legítimo.

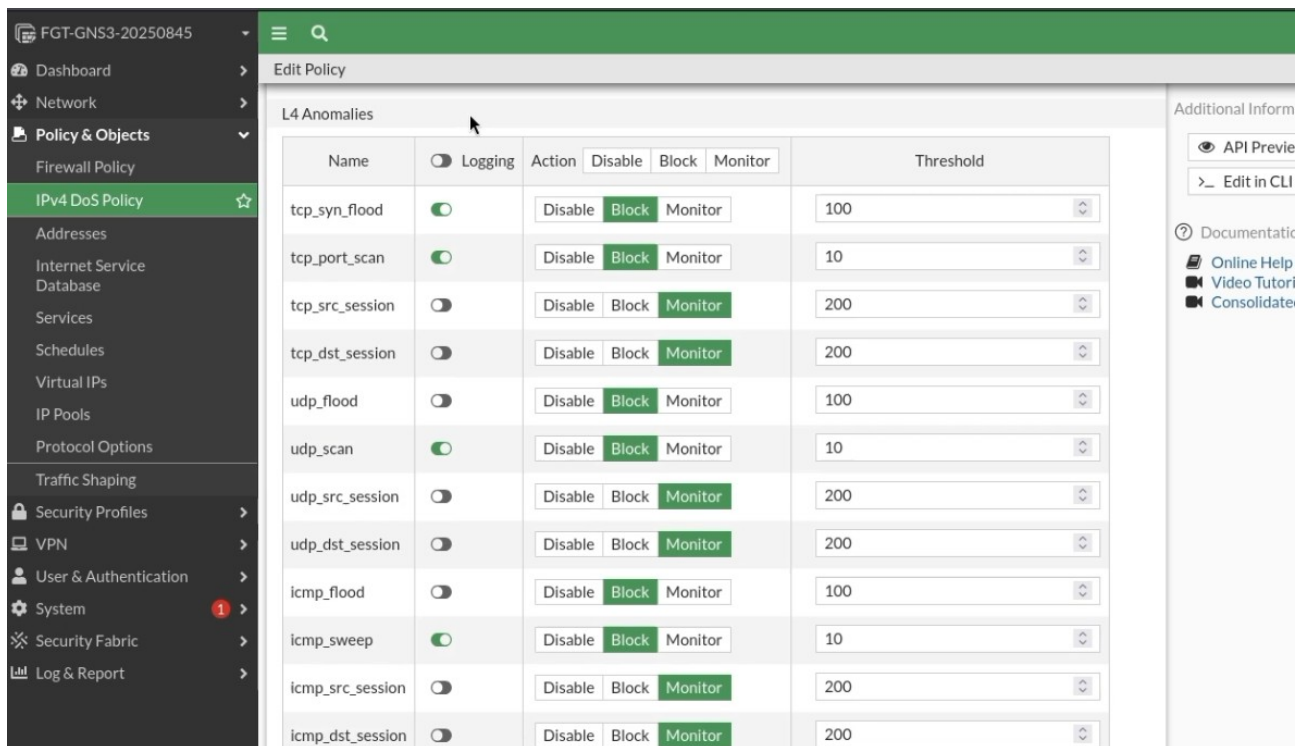


Figura 21. DoS Policy para usuarios - anomalías TCP, UDP e ICMP.

DoS Policy para usuarios - SCTP y sesiones

La tercera vista completa la política con anomalías adicionales como sctp_flood y sctp_scan en Block. También se observan controles de sesiones TCP, UDP, ICMP y SCTP en modo Monitor con umbral 200.

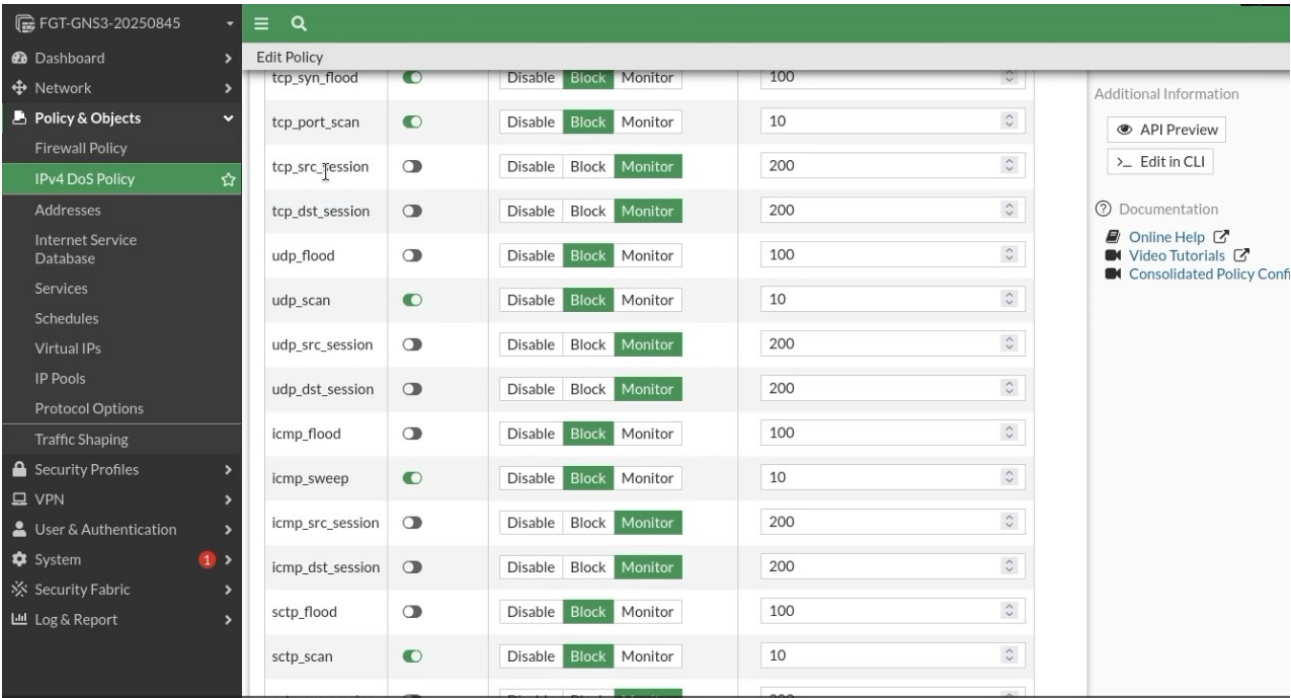


Figura 22. DoS Policy para usuarios - SCTP y sesiones.

DoS Policy aplicada en la WAN

La política DOS_BLOCK_SCANNERS_FROM_WAN se aplica sobre WAN_INTERNET port1 con origen all, destino all y servicio ALL. Esta evidencia demuestra que el control de anomalías también contempla la zona externa.

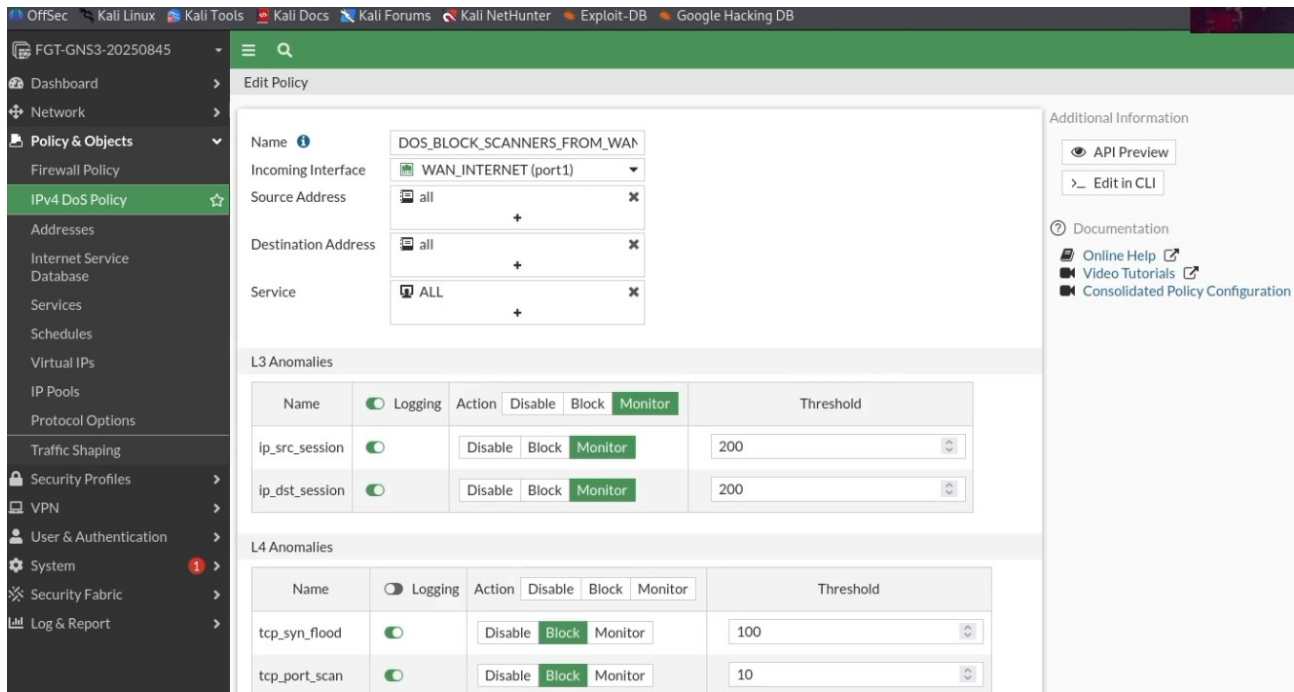


Figura 23. DoS Policy aplicada en la WAN.

Escaneo Nmap hacia el servidor web

Desde Kali se ejecuta un escaneo SYN hacia 10.8.45.130. Esta prueba genera tráfico hacia múltiples puertos del Web Server y permite validar el bloqueo por política y la detección de comportamiento anómalo.

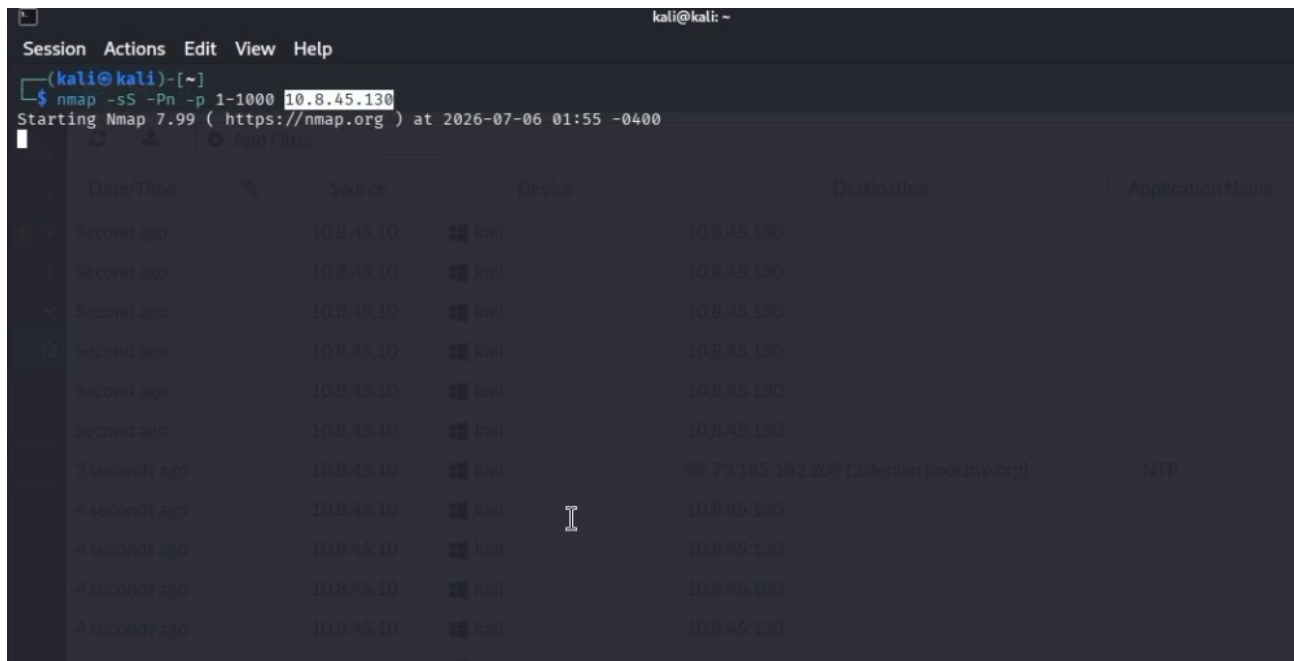
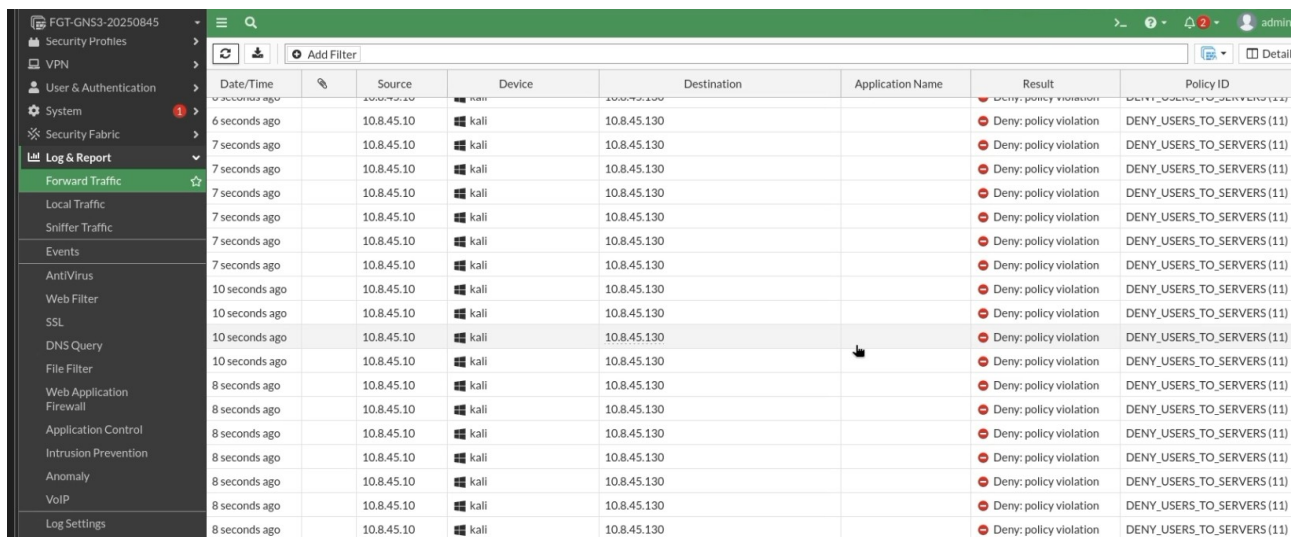


Figura 24. Escaneo Nmap hacia el servidor web.

Logs de Forward Traffic con denegación por política

En Log & Report > Forward Traffic se observan múltiples eventos desde 10.8.45.10 hacia 10.8.45.130 con resultado Deny: policy violation. La columna Policy ID muestra DENY_USERS_TO_SERVERS (11), confirmando que el tráfico no permitido hacia servidores fue bloqueado.

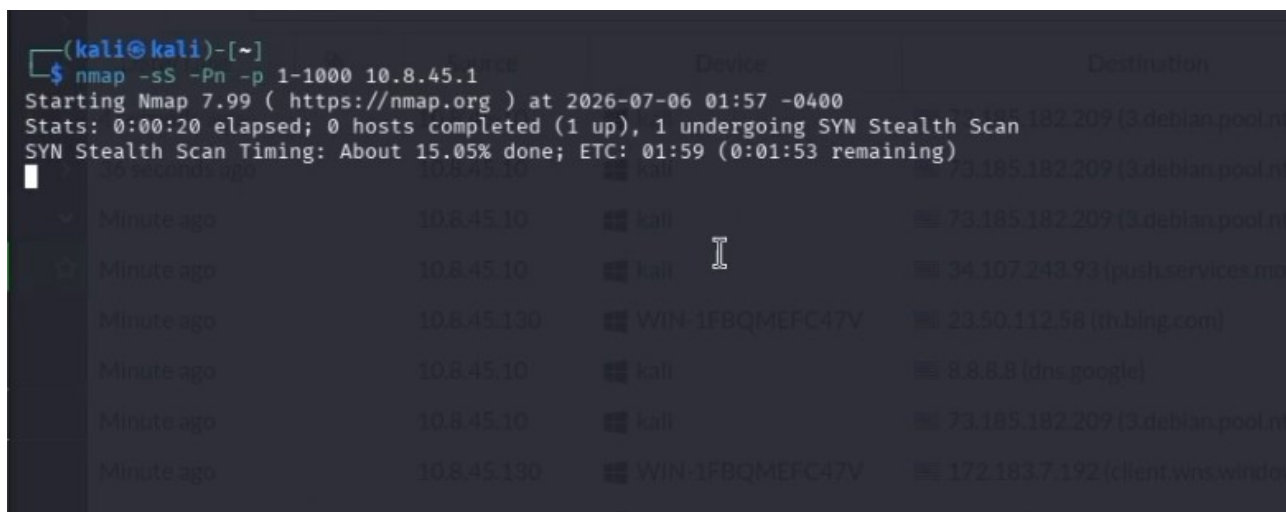


Date/Time	Source	Device	Destination	Application Name	Result	Policy ID
6 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
7 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
10 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
10 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
10 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
10 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)
8 seconds ago	10.8.45.10	kali	10.8.45.130		Deny: policy violation	DENY_USERS_TO_SERVERS (11)

Figura 25. Logs de Forward Traffic con denegación por política.

Escaneo Nmap hacia el gateway

La terminal muestra un escaneo SYN hacia 10.8.45.1, que corresponde al gateway de la LAN de usuarios en el FortiGate. Esta prueba se usó para generar tráfico de escaneo contra la propia interfaz del firewall y validar eventos de anomalía.



```
(kali@kali)-[~]
$ nmap -sS -Pn -p 1-1000 10.8.45.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 01:57 -0400
Stats: 0:00:20 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.05% done; ETC: 01:59 (0:01:53 remaining)
```

Figura 26. Escaneo Nmap hacia el gateway.

Logs de anomalías por escaneo

En Log & Report > Anomaly se observan eventos con severidad alta, acción clear_session y nombres de ataque como tcp_port_scan, tcp_syn_flood, udp_scan y udp_flood. Esto confirma que FortiGate detectó patrones de escaneo y cerró sesiones anómalas.

FGT-GNS3-20250845							
Security Profiles							
VPN							
User & Authentication							
System							
Security Fabric							
Log & Report							
Forward Traffic							
Local Traffic							
Sniffer Traffic							
Events							
AntiVirus							
Web Filter							
SSL							
DNS Query							
File Filter							
Web Application Firewall							
Application Control							
Intrusion Prevention							
Anomaly							
VoIP							
Log Settings							

Date/Time	Severity	Source	Protocol	User	Action	Count	Attack Name
28 seconds ago	■■■■■	10.8.45.10	6		clear_session	1	tcp_syn_flood
28 seconds ago	■■■■■	10.8.45.10	6		clear_session	213	tcp_port_scan
5 minutes ago	■■■■■	10.8.45.10	6		clear_session	402	tcp_port_scan
5 minutes ago	■■■■■	10.8.45.10	6		clear_session	326	tcp_port_scan
7 minutes ago	■■■■■	10.8.45.10	6		clear_session	429	tcp_port_scan
10 minutes ago	■■■■■	10.8.45.130	17		clear_session	2	udp_scan
20 minutes ago	■■■■■	10.8.45.130	6		clear_session	69	tcp_port_scan
21 minutes ago	■■■■■	10.8.45.130	6		clear_session	337	tcp_port_scan
22 minutes ago	■■■■■	142.251.154.119	17		clear_session	11	udp_flood
22 minutes ago	■■■■■	10.8.45.130	6		clear_session	182	tcp_port_scan
22 minutes ago	■■■■■	23.34.82.10	17		clear_session	675	udp_flood
23 minutes ago	■■■■■	23.62.61.208	17		clear_session	1	udp_flood
23 minutes ago	■■■■■	10.8.45.130	6		clear_session	334	tcp_port_scan
57 minutes ago	■■■■■	10.8.45.130	17		clear_session	4	udp_scan
Hour ago	■■■■■	10.8.45.130	17		clear_session	1	udp_scan
Hour ago	■■■■■	10.8.45.10	6		clear_session	1	tcp_port_scan

Figura 27. Logs de anomalías por escaneo.

9. Validación de acceso web permitido

Además de bloquear tráfico no autorizado, el laboratorio valida que el tráfico web legítimo hacia el servidor sí funciona. Las páginas internas cargan correctamente desde la red de usuarios.

Portal de empleados permitido

La página empleados.rondontech.test carga correctamente desde la estación de usuario. Se observa un portal interno de empleados de Rondón Technology, usado como evidencia de que el acceso web permitido hacia el servidor funciona.

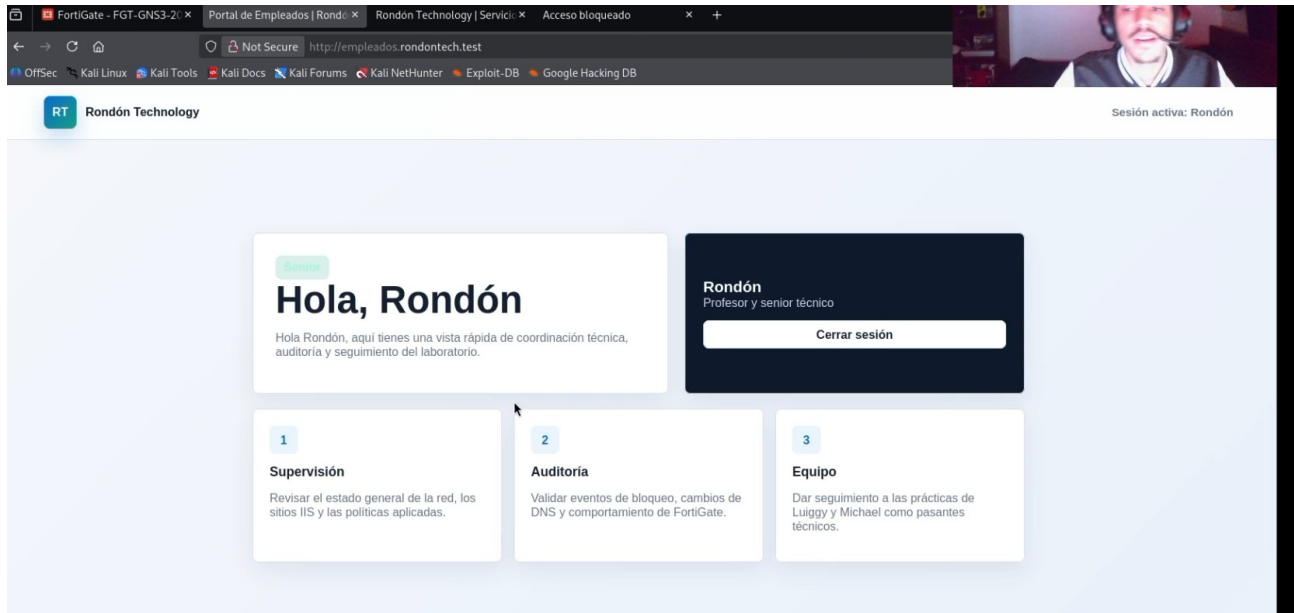


Figura 28. Portal de empleados permitido.

Sitio web público permitido

La página www.rondontech.test muestra el sitio principal de Rondón Technology. Esta prueba confirma que los usuarios pueden acceder al servicio web autorizado en el servidor 10.8.45.130.

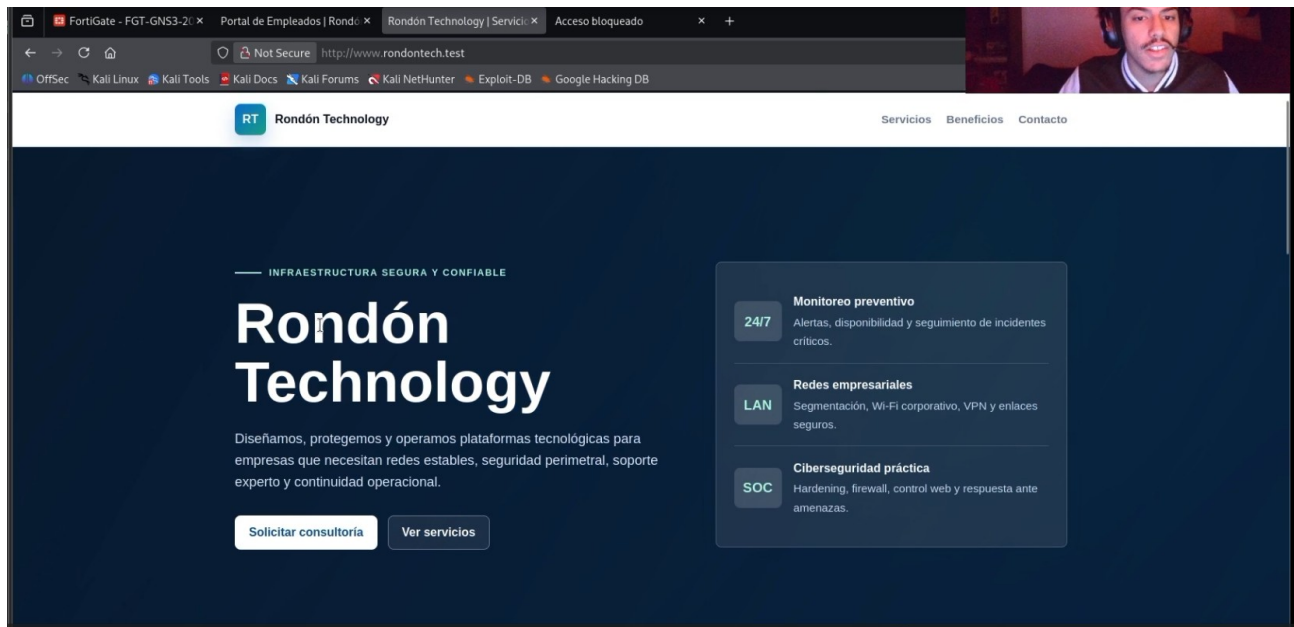


Figura 29. Sitio web público permitido.

10. Web Application Firewall

El WAF protege el servidor web contra ataques de capa de aplicación. El perfil activa firmas para XSS, SQL Injection, Generic Attacks y Known Exploits. Las pruebas demuestran que una solicitud normal recibe HTTP 200, mientras que una carga XSS es bloqueada por firma.

Perfil WAF con firmas principales

El perfil WAF_WEB_SERVER_PROTECTION contiene firmas habilitadas para Cross Site Scripting, SQL Injection, Generic Attacks, Trojans y Known Exploits con acción Block. También aparece Information Disclosure en Allow.

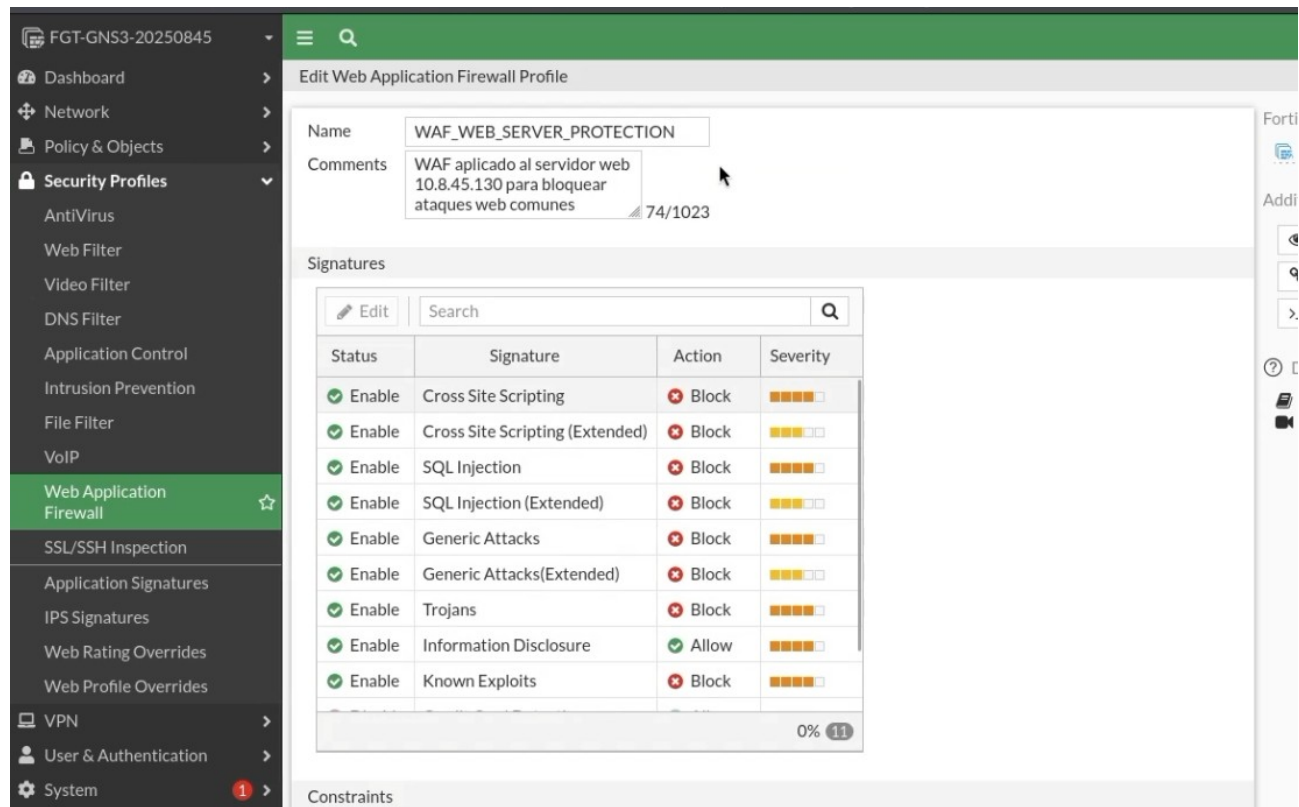


Figura 30. Perfil WAF con firmas principales.

WAF - firmas y primeros constraints

La segunda vista del WAF muestra el final de la lista de firmas, incluyendo Bad Robot en Monitor, y el inicio de los constraints. Se observan controles como Illegal HTTP Version e Illegal HTTP Request Method en Block.

FGT-GNS3-20250845

Dashboard

Network

Policy & Objects

Security Profiles

AntiVirus

Web Filter

Video Filter

DNS Filter

Application Control

Intrusion Prevention

File Filter

VoIP

Web Application Firewall

SSL/SSH Inspection

Application Signatures

IPS Signatures

Web Rating Overrides

Web Profile Overrides

VPN

User & Authentication

System

Edit Web Application Firewall Profile

Status	Signature	Action	Severity
Enable	SQL Injection	Block	
Enable	SQL Injection (Extended)	Block	
Enable	Generic Attacks	Block	
Enable	Generic Attacks(Extended)	Block	
Enable	Trojans	Block	
Enable	Information Disclosure	Allow	
Enable	Known Exploits	Block	
Disable	Credit Card Detection	Allow	
Enable	Bad Robot	Monitor	

100% 11

Constraints

Edit

Search

Status	Constraint	Limit	Action	Severity
Disable	Illegal Host Name		Allow	
Enable	Illegal HTTP Version		Block	
Enable	Illegal HTTP Request Method		Block	
Disable	Content Length	67,108,864	Allow	

Figura 31. WAF - firmas y primeros constraints.

WAF - constraints avanzados

La sección de constraints avanzados bloquea condiciones como Header Length, Header Line Length, Number of Header Lines in Request, Total URL and Body Parameters Length, Number of URL Parameters, Number of Cookies in Request, Number of Ranges in Range Header y Malformed Request.

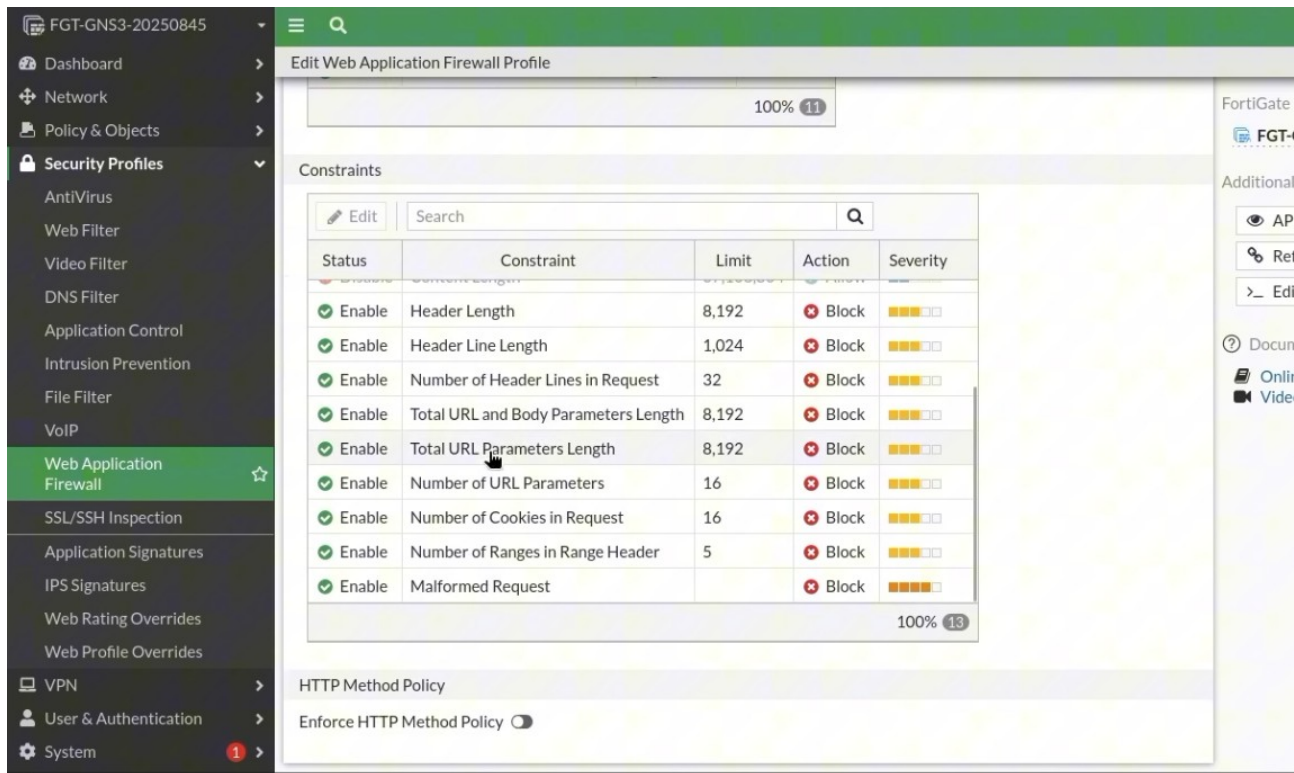


Figura 32. WAF - constraints avanzados.

Prueba web normal con HTTP 200

La terminal muestra una prueba normal hacia <http://www.rondontech.test/> con resultado Página normal: 200. Esto confirma que el WAF no bloquea una solicitud legítima hacia el sitio web.

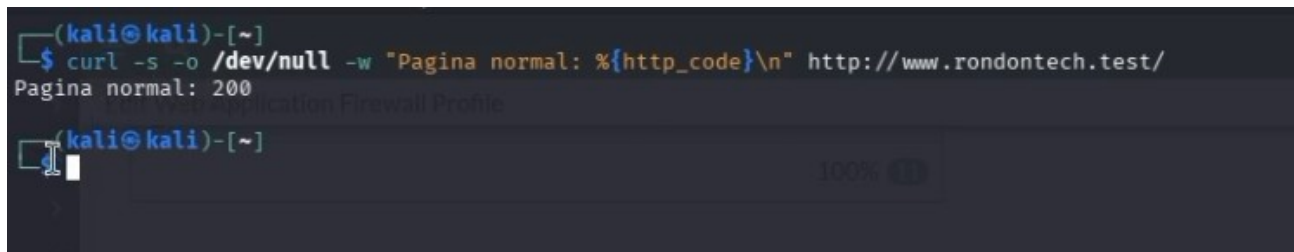


Figura 33. Prueba web normal con HTTP 200.

WAF bloqueando ataque XSS en navegador

Al intentar acceder con una carga XSS basada en `script alert(1)`, el navegador muestra la página Web Application Firewall. La evidencia incluye Event ID 10000057 y Event Type signature, indicando que el bloqueo fue producido por una firma del WAF.

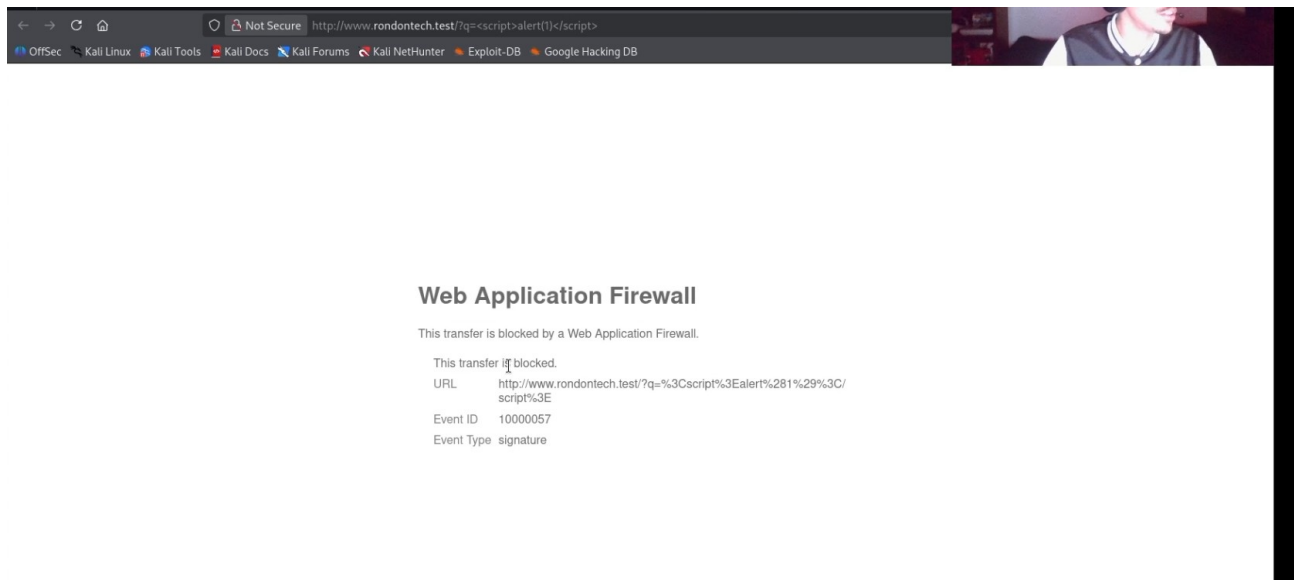


Figura 34. WAF bloqueando ataque XSS en navegador.

11. Conclusión

La implementación cumple con el objetivo de construir una política corporativa en FortiGate. Se evidencia una arquitectura segmentada, DHCP funcional para usuarios, ruta por defecto hacia Internet, NAT en políticas de salida, filtrado de redes sociales, control de WhatsApp VoIP, bloqueo y redirección del dominio itla.edu.do, detección de escáneres de red y protección WAF del servidor web.

La organización de las evidencias permite revisar el laboratorio por temas técnicos: primero la infraestructura base, luego las políticas de firewall, después los controles de contenido y aplicaciones, posteriormente la detección de escaneos y finalmente la protección del servidor web con WAF.